UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Fecha: 16 de octubre del 2026

PROPUESTA DE GOBERNANZA Y SGSI (ISO/IEC) 27001:2022

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

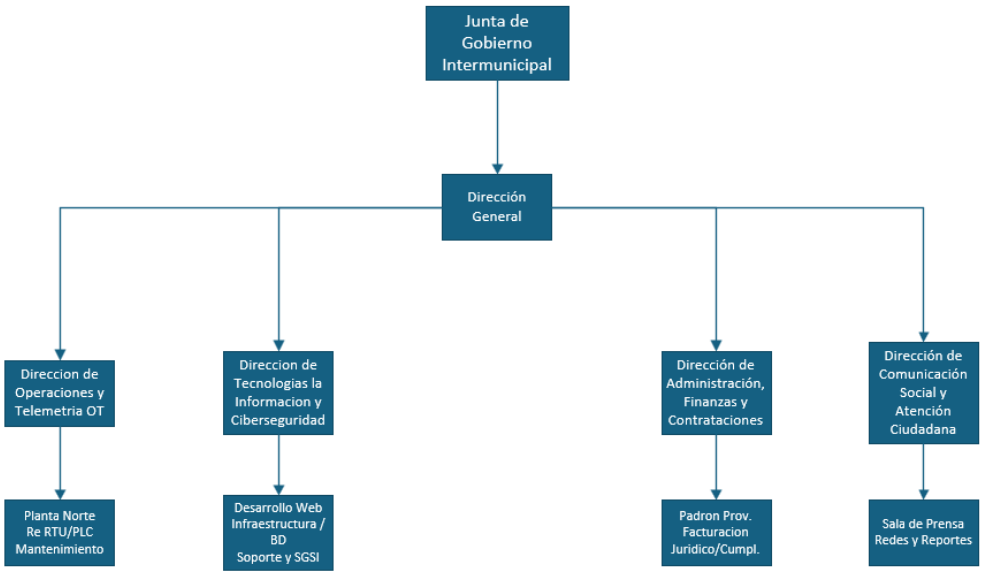
Sección 01 – Alcance 3
Organigrama Institucional..... 4
1.2 Presentación del Proyecto de Implementación ISO/IEC 27001 a la Alta Dirección 4
Sección 02 – Referencias Normativas y Marco Legal 5
2.1 Normas de la Familia ISO/IEC 27000 de Interés para INTERAFAS 5
2.2 Marcos Legales y Regulatorios Aplicables a la Institución (México) 7
Sección 03 – Términos y Definiciones 8
Sección 04 – Contexto de la Organización: Inventario de 20 Activos de Información 9
4.1 Activos de Información Internos (10 Activos) 9
4.2 Activos de Información Externos (10 Activos) 10
Sección 05 – Liderazgo y Políticas de Seguridad 11
5.2 Desarrollo de las 20 Políticas Funcionales (Una por cada Activo de Información) 12
Sección 06 – Planificación: Matriz de Riesgos y Administración del Riesgo 21
6.1 Metodología de Evaluación y Administración del Riesgo 21
6.2 Matriz de Riesgos para las 20 Políticas Funcionales 22
Seccion 07 – Soporte: Minuta de Presentación del SGSI y Soporte Documental de Prevención 23
7.1 Minuta de Reunión para Dar a Conocer el SGSI 23
7.2 Soporte Documental en Materia de Prevención.....25
A) Flyer Informativo de Prevención Interna (Diseño Textual y Visual para Distribución Institucional) 25
B) Estructura de Presentación Ejecutiva y Técnica (Diapositivas de Capacitación) ...26
C) Temario del Curso Taller de Capacitación Técnica (Duración: 8 Horas) 26
Sección 08 – Operación: Matriz de Asignación de Responsabilidades RACI.....27
Sección 09 – Evaluación del Desempeño: Lista de Verificación de Auditoría 28
Sección 10 – Mejora Continua: Rediseño de Soporte y Mejora de Política Funcional....29
10.1 Mejora de la Política Funcional POL-06 (Versión 2.0) 29
10.2 Rediseño del Soporte Documental de Prevención (Enfocado al Personal de Ingeniería y Soporte OT 29

Sección 01 – Alcance

1.1 Información Institucional de INTERAFAS

- **Historia:** Fundado en **1978**, INTERAFAS nació como el organismo público descentralizado e intermunicipal encargado de integrar y operar la infraestructura hídrica de la zona metropolitana conformada por los municipios de **Cerro de San Pablo, Saint Louis y Soledade**. A lo largo de casi cinco décadas (1978–2026), el organismo ha evolucionado desde una operación manual por pozos aislados hasta gestionar una red automatizada con telemetría industrial (OT), estaciones remotas (RTU/PLC) y servicios digitales en línea para la ciudadanía y proveedores.
- **Misión:** Garantizar el suministro continuo, eficiente y seguro de agua potable, así como los servicios de alcantarillado, saneamiento y reúso hídrico para los habitantes de Cerro de San Pablo, Saint Louis y Soledade, apoyándose en infraestructura resiliente, innovación tecnológica y transparencia institucional.
- **Visión:** Ser para el año 2030 el organismo operador de agua referente a nivel nacional en eficiencia física y comercial, reconocido por la confiabilidad de su red automatizada de distribución y la seguridad integral de la información ciudadana y operacional.
- **Objetivos Estratégicos:**
    1. Mantener una continuidad promedio del servicio superior a 23 horas diarias y una eficiencia comercial por encima del 92%.
    2. Proteger la confidencialidad de los datos personales y financieros del padrón ciudadano y de los 219 proveedores registrados.
    3. Salvaguardar la integridad y disponibilidad de los sistemas de control industrial (SCADA/HMI, PLCs y RTUs) frente a ciberamenazas que puedan comprometer la presión o calidad del agua.

Organigrama Institucional



1.2 Presentación del Proyecto de Implementación ISO/IEC 27001 a la Alta Dirección

Derivado del reciente incidente de ciberseguridad en el que una cadena de 20 vulnerabilidades permitió escalar desde el portal público hasta comprometer la unidad terminal remota RTU-GW-07 en la Planta Metropolitana Norte, se presenta a la **Alta Dirección** el proyecto de implementación del **Sistema de Gestión de Seguridad de la Información (SGSI)** basado en la norma **ISO/IEC 27001:2022**.

- **Dirección responsable:** Dirección de Tecnologías de la Información y Ciberseguridad, en coordinación directa con la Dirección de Operaciones y Telemetría OT.
- **Área de aplicación:** Subdirección de Infraestructura Digital (WebOps/Bases de Datos) y Centro de Operaciones de la Red Metropolitana (OPS-NET-20).
- **Procesos donde se ejecutará:**
    1. *Proceso de Gestión del Portal Ciudadano y Pasarela de Pagos* (autenticación, consulta de expedientes, facturación y cobro en línea).

2. *Proceso de Contrataciones Públicas y Padrón de Proveedores* (validación de procedimientos, vínculo contractual y administración de estados).
3. *Proceso de Despliegue de Software y Control de Cambios (WebOps)* (publicación de versiones, manejo de respaldos y APIs).
4. *Proceso de Supervisión, Telemetría y Mantenimiento de Firmware OT* (acceso al gateway operacional, monitoreo HMI y actualización de RTUs/PLCs).

Sección 02 – Referencias Normativas y Marco Legal

2.1 Normas de la Familia ISO/IEC 27000 de Interés para INTERAFAS

Dentro del conjunto de las 45 normas que integran la familia ISO/IEC 27000, se seleccionan aquellas directamente aplicables a la problemática técnica y operacional de INTERAFAS:

Norma	Nombre / Propósito	Aplicación en INTERAFAS
ISO/IEC 27000	Sistemas de gestión de seguridad de la información — Visión general y vocabulario.	Estandarizar los conceptos de seguridad entre el personal de IT, soporte OT y la Alta Dirección.
ISO/IEC 27001:2022	Requisitos del SGSI.	Norma certificable base para establecer, implementar, mantener y mejorar continuamente el SGSI en el portal y red OT.
ISO/IEC 27002:2022	Controles de seguridad de la información.	Guía de implementación de los 93 controles del Anexo A (desarrollo

		seguro, control de acceso, criptografía y redes).
ISO/IEC 27005	Gestión de riesgos de seguridad de la información.	Metodología para evaluar el impacto y probabilidad de amenazas sobre los 20 activos críticos del organismo.
ISO/IEC 27019	Controles de seguridad de la información para la industria de servicios públicos (*utilities*).	Extensión sectorial crítica para proteger los sistemas de control de procesos (PLCs, RTU-GW-07 y telemetría hídrica).
ISO/IEC 27035 (Partes 1-3)	Gestión de incidentes de seguridad de la información.	Marco para estructurar la detección, reporte, evaluación y respuesta ante crisis como la intrusión del Colectivo Umbral.
ISO/IEC 27701	Gestión de la información de privacidad (PIMS).	privacidad (PIMS). Protección de datos personales identificables (PII) en expedientes ciudadanos (CURP, domicilios y estados de cuenta).

2.2 Marcos Legales y Regulatorios Aplicables a la Institución (México)

Al tratarse de un organismo público descentralizado intermunicipal que maneja datos ciudadanos, recursos públicos e infraestructura hídrica, le competen los siguientes marcos legales:

1. **Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados (LGPDPPSO) y su homóloga estatal:** Aplicable directamente por la exposición de datos personales (nombre, CURP, teléfono, domicilio y consumos) ocurrida mediante las vulnerabilidades IDOR en expediente.php y BOLA en /api/service-history.php.
2. **Ley General de Transparencia y Acceso a la Información Pública (LGTAIP):** Regula las obligaciones de transparencia en contrataciones y licitaciones (/transparencia.php, /contrataciones.php), exigiendo publicar datos abiertos sin comprometer la seguridad de la infraestructura ni exponer código fuente (.bak).
3. **Ley de Aguas Nacionales y Normatividad de CONAGUA / CEA:** Establece la obligación de garantizar la continuidad, presión regulada y calidad del suministro público de agua potable como servicio vital y de seguridad nacional.
4. **Ley de Obras Públicas y Servicios Relacionados / Ley de Adquisiciones:** Regula la integridad legal del padrón de proveedores (/gestion-proveedores.php) y la validación de vínculos contractuales (/validar-vinculo-contractual.php).
5. **Código Penal Federal (Artículos 211 bis 1 al 211 bis 7):** Tipifica los delitos en materia de acceso ilícito a sistemas y equipos de informática, aplicable para proceder legalmente ante accesos no autorizados o sabotaje a sistemas del Estado.

Sección 03 – Términos y Definiciones

Con el fin de contextualizar esta propuesta ante la Alta Dirección, se definen **8 términos fundamentales** extraídos de los 81 conceptos del vocabulario oficial de la norma (ISO/IEC 27000 / ISO/IEC 27001):

1. **Activo de información:** Cualquier dato, documento, software, componente físico o servicio que tiene valor para INTERAFAS y requiere protección (por ejemplo, la base de datos interafas, el código del portal o la unidad RTU-GW-07).
2. **Confidencialidad:** Propiedad por la cual la información no se pone a disposición ni se revela a individuos, entidades o procesos no autorizados (vulnerada en INTERAFAS cuando un ciudadano pudo leer el expediente de otro titular o la topología OT).
3. **Integridad:** Propiedad de exactitud y completitud de la información y los métodos de procesamiento (vulnerada cuando se permitió alterar el monto de pago a $1.00 o instalar firmware modificado sin firma digital).
4. **Disponibilidad:** Propiedad de que la información y los sistemas operativos sean accesibles y utilizables cuando los requiera una entidad autorizada (comprometida cuando la planta cayó al 4.10% de operatividad tras alterar el setpoint de presión).
5. **Vulnerabilidad:** Debilidad de un activo o de un control que puede ser explotada por una o más amenazas (representada por los 20 hallazgos técnicos documentados en el laboratorio).
6. **Amenaza:** Causa potencial de un incidente no deseado, el cual puede resultar en daño a un sistema o a la organización (ej. actores externos como el *Colectivo Umbral* ejecutando ataques de inyección SQL o sabotaje OT).
7. **Riesgo de seguridad de la información:** Efecto de la incertidumbre sobre los objetivos de seguridad, expresado como la combinación de las consecuencias de un evento (impacto) y la probabilidad de que ocurra.

8. **Control:** Medida que modifica o mantiene el riesgo (incluye políticas, procedimientos, directrices, prácticas o estructuras organizacionales de carácter preventivo, detectivo o correctivo).

Sección 04 – Contexto de la Organización: Inventario de 20 Activos de Información

Se definen **20 activos de información** críticos para la operación de INTERAFAS, divididos equitativamente en **10 activos internos** (infraestructura de backend, bases de datos y red industrial OT) y **10 activos externos** (portales, APIs y servicios expuestos hacia los ciudadanos y proveedores):

4.1 Activos de Información Internos (10 Activos)

1. **ACT-INT-01: Base de Datos Institucional (db:3306 / schema interafas)** — Servidor MySQL/MariaDB que aloja las 32 tablas operativas, ciudadanas y de soporte.
2. **ACT-INT-02: Unidad Terminal Remota / Gateway de Borde (RTU-GW-07)** — Dispositivo crítico de interfaz remota en la Planta Metropolitana Norte que regula el setpoint de presión (4.2 bar).
3. **ACT-INT-03: Consola de Operaciones e Inventario SCADA (HMI-OPS-01)** — Sistema central de visualización y control de las 12 estaciones y 37 activos OT.
4. **ACT-INT-04: Controladores Lógicos Programables Municipales (PLC-SL-01 / PLC-CP-01)** — Autómatas de control de área encargados de regular bombas (P-SL-101) y válvulas (V-SL-201).
5. **ACT-INT-05: Servidor de Historial de Procesos (HIST-01) y Respaldo (BRS-01)** — Sistemas de almacenamiento de series de tiempo operacionales y catálogo de recuperación de configuración OT.
6. **ACT-INT-06: Paquetes de Firmware y Backups de Configuración OT (package.php / RTU-GW-07-backup.json)** — Archivos binarios/JSON que definen el modo de operación y bloqueo de diagnóstico de las RTUs.

7. **ACT-INT-07: Tabla de Credenciales de Soporte Industrial (firmware_support_users / operational_users)** — Registro de identidades y hashes de acceso del personal de ingeniería y mantenimiento OT.
8. **ACT-INT-08: Paquetes de Despliegue y Configuración WebOps (release-check.env, app-release.ini, rsync.log)** — Artefactos generados por la estación WEBOPS-03 para la puesta en producción del portal.
9. **ACT-INT-09: Gateway de Interconexión IT/OT (operations-bridge / Subred 10.40.20.0/24)** — Puente lógico de red que comunica el servidor web con el segmento privado operacional OPS-NET-20.
10. **ACT-INT-10: Servidor Linux Debian y Sistema de Archivos Base (/var/www/html, /etc/passwd, /etc/motd)** — Sistema operativo subyacente y servicio Apache/2.4.68 con PHP 8.3.35.

4.2 Activos de Información Externos (10 Activos)

11. **ACT-EXT-01: Portal de Autenticación y Gestión de Sesiones Ciudadanas (/login.php, /panel.php, /perfil.php)** — Interfaz de acceso para titulares del servicio de agua potable.
12. **ACT-EXT-02: Módulo de Expedientes Administrativos Ciudadanos (/expediente.php)** — Sistema de consulta de datos personales (CURP, dirección, teléfono) y trámites de aclaración.
13. **ACT-EXT-03: Servicio de Descarga de Constancias y Documentos (/documentos.php y /descargar-documento.php)** — Repositorio digital de constancias de no adeudo, titularidad y servicio en PDF.
14. **ACT-EXT-04: Pasarela de Pago en Línea y Facturación (/pago.php y /factura.php)** — Módulo transaccional para liquidación de recibos mediante tarjeta, SPEI o domiciliación.
15. **ACT-EXT-05: API de Historial de Servicio y Contexto de Cuenta (/api/account-context.php y /api/service-history.php)** — Servicios REST/JSON que alimentan el estado de contratos y saldos por cuenta.

16. **ACT-EXT-06: Módulo de Recepción y Seguimiento de Reportes Ciudadanos (/reportes.php y /seguimiento-reporte.php)** — Canal de atención pública para reportar fugas, baja presión y fallas de alcantarillado.
17. **ACT-EXT-07: Portal de Transparencia y Exportador de Datos Abiertos (/transparencia.php, /observatorio.php y /exportar.php)** — Plataforma de consulta de indicadores hídricos y descarga de contratos en CSV/JSON.
18. **ACT-EXT-08: Módulo de Administración del Padrón de Proveedores (/proveedores.php y /gestion-proveedores.php)** — Sistema de consulta pública y gestión administrativa de los 219 contratistas.
19. **ACT-EXT-09: Servicio de Validación de Procedimientos y Vínculos Contractuales (/validar-referencia.php y /validar-vinculo-contractual.php)** — Herramientas públicas de verificación de licitaciones y contratos adjudicados.
20. **ACT-EXT-10: Portal Institucional de Infraestructura y Sala de Prensa (/infraestructura.php, /api/infrastructure-status.php, /prensa.php)** — Canal informativo oficial sobre el estado de la red metropolitana y comunicados.

Sección 05 – Liderazgo y Políticas de Seguridad

5.1 Política General de Seguridad de la Información de INTERAFAS

Declaración de la Alta Dirección:

"INTERAFAS asume el compromiso de proteger la confidencialidad, integridad y disponibilidad de la información de sus usuarios, sus sistemas web y su infraestructura operacional (OT) encargada del suministro de agua en Cerro de San Pablo, Saint Louis y Soledade. Para lograrlo, la organización establece y mantiene este Sistema de Gestión de Seguridad de la Información (SGSI) basado en la norma ISO/IEC 27001, obligando a todas sus áreas a cumplir con los controles de seguridad, la legislación vigente y la mejora continua de sus procesos."

5.2 Desarrollo de las 20 Políticas Funcionales (Una por cada Activo de Información)

De acuerdo con los requerimientos de la rúbrica, cada una de las 20 políticas funcionales integra su **Estándar**, **Directriz**, **Procedimiento** y **Línea Base** correspondiente:

ID Política y Activo Asociad	Política Funcional (Declaración)	Estándar (Control ISO / Técnico)	Directriz (Guía de Actuación)	Procedimiento (Pasos de Ejecución)	Línea Base (Métrica / Configuración Mínima)
POL-01	Todas las consultas hacia la base de datos institucional deberán garantizar el aislamiento entre datos e instrucciones SQL y restringir privilegios por servicio.	ISO 27002 **8.28** (Codificación segura) / OWASP ASVS V5.	Prohibir la concatenación directa de variables de usuario en consultas SQL en cualquier módulo PHP.	1. Conectar vía PDO. 2. Preparar sentencia con placeholders (? o :param). 3. Ejecutar bindParam() y validar tipos.	100% de consultas con *Prepared Statements*; usuario de BD web sin permisos de lectura sobre tablas OT (firmware_support_users)
POL-02	Los puntos de ajuste (*setpoints*) operativos de las unidades RTU solo podrán modificarse dentro de umbrales físicos seguros y con doble autorización.	ISO 27019 / ISA 62443-3-3 (Validación de entradas operacionales).	Ninguna interfaz de software permitirá establecer presiones que comprometan la integridad hidráulica de la red.	1. Solicitar cambio en ventana activa. 2. Validar rango en backend. 3. Aprobar por supervisor OT.	Rango estricto de pressure_setpoint_bar bloqueado por código y PLC entre **3.5 bar y 4.8 bar** (nominal **4.2 bar**).

				4. Aplicar en RTU.	
POL-03	El acceso a la consola HMI y al inventario de activos OT estará restringido por roles y alcance de zona operativa.	ISO 27002 **8.2** (Derechos de acceso privilegiado) y **5.15**.	Las sesiones de mantenimiento externo o de soporte solo tendrán visibilidad sobre el activo intervenido.	1. Autenticar operador con MFA. 2. Verificar ventana de mantenimiento. 3. Filtrar en API /operations /asset-context.php solo activos autorizados.	Bloqueo de recorrido de dependencias (Scope: single-asset); expiración de sesión HMI a los **15 minutos** de inactividad.
POL-04	Los controladores PLC de área contarán con enclavamientos lógicos locales (*safety interlocks*) independientes del gateway central.	ISO 27019 / NIST SP 800-82 (Protección de dispositivos de campo).	Priorizar la seguridad física de bombas y válvulas ante órdenes anómalas provenientes de la red superior.	1. Monitorear presión local en cada ciclo de escaneo. 2. Si supera el umbral, abrir válvula de alivio y rechazar comando remoto.	Enclavamiento local activo en los **18 PLCs**; desconexión automática a modo local seguro si la presión excede **5.0 bar**.

POL-05	Las copias de recuperación de configuración OT y bitácoras del historiador deberán resguardarse de forma inmutable y verificada.	ISO 27002 **8.13** (Respaldo de la información) y **8.15** (Registros).	Asegurar la restauración inmediata (*rollback*) de configuraciones válidas en caso de sabotaje o falla en cascada.	1. Generar snapshot diario en BRS-01. 2. Firmar hash del respaldo. 3. Almacenar copia fuera de línea. 4. Probar restauración semanal.	Retención mínima de **90 días** en HIST-01; catálogo BRS-01 en modo solo lectura para cuentas de mantenimiento.
POL-06	Todo paquete de actualización de firmware para dispositivos OT deberá estar firmado criptográficamente antes de su instalación.	ISO 27002 **8.24** (Uso de criptografía) y OWASP A08 (Integridad de software).	No confiar únicamente en sumas de comprobación simples (SHA-256) enviadas dentro de la misma petición del cliente.	1. Firmar paquete con llave privada de ingeniería. 2. En install.php, verificar firma con llave pública. 3. Si falla, abortar y alertar.	Firma digital **RSA-2048 o ECDSA** obligatoria (Signature-Verification: enforced); estado por defecto diagnostic: LOCKED.
POL-07	Las contraseñas de cuentas operacionales y de	ISO 27002 **5.17** (Información de autenticación) y **8.24**.	Queda estrictamente prohibido el uso de algoritmos obsoletos	1. Exigir longitud mínima y rotación.	Algoritmo **Argon2id** (o **bcrypt cost** $\geq$ **12**); longitud mínima de **14 caracteres**; bloqueo tras **5 intentos** fallidos.

	soporte deberán almacenarse con algoritmos de hashing adaptativos con sal y políticas de complejidad.		como MD5 o SHA-1 sin sal para resguardar contraseñas.	2. Procesar contraseña con password_hash() usando Argon2id o bcrypt.	
POL-08	Ningún paquete comprimido de despliegue, archivo .env o bitácora de sincronización deberá alojarse dentro del directorio público web.	ISO 27002 **8.32** (Gestión de cambios) y **8.9** (Gestión de configuración).	Separar estrictamente los artefactos de compilación/despliegue de la ruta pública /var/www/html.	1. Subir paquete a /opt/releases/ (fuera del web root). 2. Sincronizar solo vistas públicas. 3. Ejecutar script de limpieza y verificar con checklist.	0 archivos .zip, .env, .log o .ini dentro de /var/www/html; variable CLEANUP_RELEASE_FILES auditada automáticamente.
POL-09	El cruce de tráfico hacia el segmento operacional OPS-NET-20 deberá autenticarse a nivel de red e identidad, sin confiar en	ISO 27002 **8.22** (Segregación de redes) y **8.20** (Seguridad de redes).	Descartar por completo el uso de X-Forwarded-For o X-Real-IP como mecanismo de autorización en pasarelas internas.	1. Aislar subred 10.40.20.0/24 tras firewall industrial (DMZ). 2. Exigir VPN con certificado mutuo (mTLS).	Regla de firewall DENY ALL desde el contenedor web público hacia 10.40.20.0/24; X-Forwarded-For ignorado en gateway.php.

	cabeceras HTTP.			3. Validar IP real de socket (REMOTE_ADDR).	
POL-10	El servidor web Apache y el entorno PHP deberán endurecerse (*hardening*) para impedir el listado de directorios y la entrega de archivos de respaldo.	ISO 27002 **8.9** (Gestión de la configuración) / CIS Apache Benchmark.	Ocultar versiones de software y bloquear a nivel servidor cualquier extensión que no sea requerida en producción.	1. Configurar Options -Indexes. 2. Bloquear extensiones residuales con <FilesMatch>. 3. Ocultar ServerTokens y expose_php.	Options -Indexes global; bloqueo 403 para .bak, .old, .swp, .orig, ~; ServerTokens Prod y expose_php = Off.
POL-11	Todo inicio de sesión exitoso deberá regenerar el identificador de sesión y proteger las cookies contra robo o reutilización.	ISO 27002 **8.5** (Autenticación segura) / OWASP Session Management.	Evitar ataques de fijación y *replay* de sesión invalidando cualquier PHPSESSID emitido antes del login.	1. Validar credenciales en POST /login.php. 2. Invocar session_regenerate_id(true). 3. Vincular sesión a User-Agent/IP y destruir al salir.	session.use_strict_mode = 1, flags HttpOnly, Secure y SameSite=Strict activos en PHPSESSID.

POL-12	El acceso a expedientes administrativos ciudadanos deberá validar estrictamente la titularidad del objeto en el servidor.	ISO 27002 **8.3** (Restricción de acceso a la información) y **5.34** (Privacidad).	Ningún usuario autenticado podrá consultar información personal (CURP, dirección) de otro ciudadano modificando parámetros URL.	1. Recibir solicitud en expediente.php. 2. Obtener user_id desde $_SESSION. 3. Consultar únicamente el expediente vinculado a ese user_id.	Eliminación del parámetro GET ?id= (o validación WHERE id = :id AND user_id = :session_uid); registro en log de intentos IDOR.
POL-13	La descarga de constancias en PDF deberá restringirse al directorio autorizado sin permitir navegación por rutas relativas.	ISO 27002 **8.3** y **8.28** (Prevención de Path Traversal - CWE-22).	Nunca pasar directamente el nombre de archivo enviado por el usuario a funciones de lectura del sistema de archivos.	1. Limpiar entrada con basename($_GET['file']). 2. Resolver ruta con realpath(). 3. Verificar prefijo del directorio base y pertenencia del documento al usuario.	Prohibición de caracteres .., / y \ en el parámetro file; mapeo por ID de documento en BD en lugar de nombre de archivo.
POL-14	El procesamiento de pagos en línea	ISO 27002 **8.26** (Requisitos de seguridad	El cliente web nunca deberá dictar el monto	1. Recibir factura_id en POST /pago.php.	Parámetro monto eliminado del POST; validación transaccional ACID que rechaza pagos

	deberá calcular y validar el importe a liquidar exclusivamente desde la base de datos en el servidor.	de las aplicaciones).	financiero de una transacción mediante campos de formulario editables.	2. Consultar saldo_pendiente real en la tabla facturas. 3. Procesar cobro por el saldo exacto de BD.	inferiores al saldo registrado.
POL-15	Todos los endpoints de la API deberán estar inventariados, documentados y contar con autorización a nivel de objeto (BOLA).	ISO 27002 **8.26** / OWASP API Security Top 10 (API1 y API9).	No mantener rutas de API ocultas o sin documentar activas en producción ni asumir que el usuario solo consultará su propia cuenta.	1. Registrar endpoint en catálogo OpenAPI. 2. En service-history.php, comprobar que account pertenezca al titular en sesión. 3. Retornar 403 si no coincide.	100% de endpoints documentados; validación obligatoria de propiedad de account contra $_SESSION['user_id'] .
POL-16	Toda entrada de texto libre proporcionada por ciudadanos deberá sanitizarse y codificarse	ISO 27002 **8.28** (Codificación segura contra XSS) y **8.26**.	Tratar todo contenido almacenado en base de datos como no confiable al momento de construir vistas HTML	1. Validar longitud y formato en reportes.php. 2. Al mostrar en seguimient	htmlspecialchars() en el 100% de salidas dinámicas; cabecera Content-Security-Policy: default-src 'self'; script-src 'self' activa.

	antes de renderizarse en el navegador.		de seguimiento.	o-reporte.php, aplicar htmlspecialchars($texto, ENT_QUOTES, 'UTF-8'). 3. Enviar cabecera CSP.	
POL-17	Los módulos de exportación de datos abiertos deberán manejar las excepciones de forma controlada sin exponer trazas de depuración en producción.	ISO 27002 **8.9** y **8.28** (Manejo seguro de errores y excepciones).	Los mensajes de error mostrados al público deben ser genéricos, registrando los detalles técnicos únicamente en logs internos del servidor.	1. Incluir cláusula default en el match($tipo) de exportar.php. 2. Registrar error en /var/log/apache2/error.log. 3. Mostrar vista amigable 400 Bad Request.	display_errors = Off y log_errors = On en php.ini; modo DEBUG RESPONSE deshabilitado en el entorno production.
POL-18	El control de acceso a funciones administrativas del padrón de proveedores se validará	ISO 27002 **5.15** (Control de acceso) y **8.2** (Privilegios).	Prohibir el uso de cookies del lado del cliente (portal_role) para determinar el nivel de	1. Eliminar cookie portal_role. 2. Almacenar rol en $_SESSION	Autorización 100% *server-side*; supresión total de la cabecera X-Required-Role en respuestas HTTP.

	estrictamente mediante sesiones en el servidor.		privilegio de un usuario.	['role'] desde BD. 3. Si no es procurement_admin, devolver 403 sin cabecera X-Required-Role.	
POL-19	Las consultas públicas de validación contractual deberán comprobar la integridad relacional entre el contrato y el proveedor.	ISO 27002 **8.26** (Integridad de reglas de negocio y validación relacional).	No dar por válido un vínculo contractual verificando la existencia de las entidades de manera aislada.	1. Recibir contract_id y provider_id. 2. Ejecutar SELECT con INNER JOIN verificando que contratos.proveedor_id = proveedores.id. 3. Mostrar resultado real.	Llave foránea (FOREIGN KEY) activa en tabla contratos; rechazo inmediato de combinaciones cruzadas entre proveedores.
POL-20	Los portales institucionales y APIs de estado público no deberán exponer metadatos de diagnóstico, rutas	ISO 27002 **8.12** (Prevención de fuga de datos) y **8.20**.	Separar los indicadores de comunicación ciudadana de las herramientas de diagnóstico de red de ingeniería.	1. Auditar campos JSON de infrastructure-status.php y build-manifest.php.	0 direcciones IP privadas (10.40.20.0/24), nombres de RTUs o tokens de QA presentes en respuestas JSON públicas.

	internas ni direccionamiento IP operacional.			2. Suprimir bloques diagnostics y quality_assurance. 3. Publicar solo KPIs generales.	

Sección 06 – Planificación: Matriz de Riesgos y Administración del Riesgo

6.1 Metodología de Evaluación y Administración del Riesgo

Para administrar los riesgos asociados a las 20 políticas funcionales y sus activos en INTERAFAS, se aplica una metodología basada en **ISO/IEC 27005**

Probabilidad (P): Escala de **1 a 5** (*1 = Improbable, 2 = Posible, 3 = Probable, 4 = Muy Probable, 5 = Casi Seguro*).

Impacto (I): Escala de **1 a 5** sobre Confidencialidad, Integridad, Disponibilidad y Continuidad OT (*1 = Insignificante, 2 = Menor, 3 = Moderado, 4 = Mayor, 5 = Catastrófico*).

Nivel de Riesgo Inherente ($R = P \times I$):

- **Bajo (1–5):** Aceptar / Monitorear.
- **Medio (6–11):** Mitigar mediante controles programados.
- **Alto (12–19):** Mitigar de forma prioritaria a corto plazo.
- **Crítico (20–25):** Mitigación inmediata obligatoria (inaceptable para la operación hídrica).

Estrategia de Tratamiento del Riesgo:

1. **Mitigar (Reducir):** Implementar los controles técnicos y organizacionales definidos en el Anexo A de ISO/IEC 27002:2022 y las 20 políticas funcionales.
2. **Evitar (Eliminar):** Retirar de producción funcionalidades o exposiciones innecesarias (como el modo Debug activo, archivos .bak/.zip en el web root y bloques de diagnóstico OT en APIs públicas).
3. **Transferir (Compartir):** Contratar pólizas de ciberseguro institucional y exigir cláusulas de responsabilidad e indemnización a terceros proveedores de desarrollo y telemetría.
4. **Aceptar (Retener):** Únicamente aplicable al riesgo residual una vez que este se encuentre en nivel **Bajo (≤ 5)** previa firma de la Alta Dirección.

6.2 Matriz de Riesgos para las 20 Políticas Funcionales

ID Riesgo	Política	Activo afectado	Amenaza identificada (escenario INTERAFAS-LAB)	Vulnerabilidad asociada	P	I	Riesgo inherente (P×I)	Nivel inherente	Estrategia	Control aplicado (ISO 27002:2022)	Riesgo residual	Nivel residual
RSG-01	POL-01	ACT-INT-01: BD interafas	Extracción masiva de las 32 tablas mediante inyección SQL automatizada (sqlmap).	Concatenación de parámetro GET ref sin sentencias preparadas (VULN-07).	5	5	25	Crítico	Mitigar	Consultas preparadas PDO y mínimo privilegio de BD (Control 8.28 y 8.3).	4	Bajo
RSG-02	POL-02	ACT-INT-02: RTU-GW-07	Sabotaje ciberfísico por sobrepresión (10 bar) y ruptura de red metropolitana.	Falta de límites hidráulicos y doble firma en carga JSON (VULN-20).	5	5	25	Crítico	Mitigar	Candado de rango (3.5–4.8 bar) y doble firma de ingeniería (Control 8.26 / ISO 27019).	5	Bajo
RSG-03	POL-03	ACT-INT-03: HMI-OPS-01	Mapeo completo de dependencias operacionales hacia zonas terminales (ZONE-SL-A).	Exceso de alcance en sesión de mantenimiento en /operations/asset-context.php (VULN-19).	4	4	16	Alto	Mitigar	Control de acceso basado en alcance de ventana activa y MFA (Control 5.15 y 8.2).	4	Bajo
RSG-04	POL-04	ACT-INT-04: PLC-SL-01	Cascada de fallas en bombas y válvulas municipales por órdenes remotas corruptas.	Ausencia de desacoplamiento y protección local en PLCs de estación (VULN-20).	4	5	20	Crítico	Mitigar	Enclavamientos físicos/lógicos (safety interlocks) locales en los 18 PLCs (ISO 27019).	4	Bajo
RSG-05	POL-05	ACT-INT-05: HIST-01 / BRS-01	Alteración o indisponibilidad de catálogos de recuperación durante una crisis OT.	Exposición de sistemas de respaldo en la misma cadena del gateway comprometido.	3	5	15	Alto	Mitigar	Respaldos inmutables fuera de línea y pruebas de rollback (Control 8.13 y 8.15).	3	Bajo
RSG-06	POL-06	ACT-INT-06: Firmware OT	Inyección de firmware alterado que desbloquea el modo diagnóstico (UNLOCKED).	Validación limitada a checksum SHA-256 sin firma digital (VULN-18).	5	5	25	Crítico	Mitigar	Verificación obligatoria de firma criptográfica RSA/ECDSA en install.php (Control 8.24).	4	Bajo
RSG-07	POL-07	ACT-INT-07: Usuarios Soporte OT	Compromiso de cuenta de soporte de firmware mediante ataque de diccionario/reglas (hashcat).	Uso de algoritmo obsoleto SHA-1 sin sal para almacenar contraseñas (Soporte343) (VULN-18).	5	5	25	Crítico	Mitigar	Hashing con Argon2id/bcrypt, contraseñas robustas y MFA (Control 5.17 y 8.24).	4	Bajo
RSG-08	POL-08	ACT-INT-08: Artefactos WebOps	Descarga no autorizada de paquetes de release (.zip), tokens .env y bitácoras.	Omisión de limpieza post-despliegue bajo /assets/docs/public/revision/ (VULN-01).	5	4	20	Crítico	Evitar / Mitigar	Alojar releases fuera de /var/www/html y automatizar depuración CI/CD (Control 8.32).	2	Bajo
RSG-09	POL-09	ACT-INT-09: Gateway IT/OT	Cruce no autorizado desde el portal público hacia la red operacional 10.40.20.0/24.	Confianza en cabecera falsificable X-Forwarded-For en gateway.php (VULN-16).	5	5	25	Crítico	Mitigar	Segregación física/VLAN con firewall industrial, VPN mTLS e ignorar cabeceras proxy (Control 8.22).	4	Bajo
RSG-10	POL-10	ACT-INT-10: Servidor Debian/Web	Lectura de código fuente PHP en texto plano y exploración de estructura de carpetas.	Options +Indexes activo y archivo residual transparencia.php.bak expuesto (VULN-01, 04).	5	4	20	Crítico	Evitar / Mitigar	Deshabilitar índices (-Indexes) y bloquear extensiones .bak/.old/.swp (Control 8.9).	2	Bajo
RSG-11	POL-11	ACT-EXT-01: Login Ciudadano	Secuestro y reutilización indefinida de sesiones ciudadanas activas (Session Replay).	Ausencia de rotación de PHPSESSID tras autenticarse en /login.php (VULN-10).	4	4	16	Alto	Mitigar	Regeneración obligatoria de ID de sesión y atributos HttpOnly/Strict (Control 8.5).	4	Bajo
RSG-12	POL-12	ACT-EXT-02: /expediente.php	Fuga masiva de datos personales (CURP, domicilio, teléfono) del padrón ciudadano.	Falta de control de pertenencia sobre el parámetro GET ?id= (IDOR - VULN-03).	5	4	20	Crítico	Mitigar	Consulta vinculada estrictamente al user_id de la sesión del servidor (Control 8.3 y 5.34).	4	Bajo
RSG-13	POL-13	ACT-EXT-03: Descarga PDF	Extracción de archivos internos del sistema operativo (/etc/passwd, /etc/motd).	Falta de sanitización de secuencias ../ en parámetro GET file (VULN-09).	5	4	20	Crítico	Mitigar	Uso de basename(), realpath() y descarga por ID referenciado en BD (Control 8.28).	3	Bajo
RSG-14	POL-14	ACT-EXT-04: Pasarela /pago.php	Quebranto financiero por liquidación de facturas de agua con pagos de $1.00.	Confianza en el parámetro POST monto enviado por el cliente sin revalidar en BD (VULN-13).	5	4	20	Crítico	Mitigar	Eliminar monto del request y cobrar exclusivamente el saldo registrado en BD (Control 8.26).	3	Bajo
RSG-15	POL-15	ACT-EXT-05: /api/service-history	Enumeración automatizada de contratos, municipios y adeudos de cuentas ajenas.	Endpoint oculto sin documentar (VULN-11) y sin autorización de objeto BOLA (VULN-12).	5	4	20	Crítico	Mitigar	Inventario OpenAPI y validación de propiedad de account en sesión (Control 8.3 y 8.26).	4	Bajo
RSG-16	POL-16	ACT-EXT-06: /reportes.php	Ejecución de JavaScript malicioso en navegadores de ciudadanos y personal de soporte.	Almacenamiento y renderizado de Descripción sin sanitizar ni codificar (Stored XSS - VULN-08).	4	4	16	Alto	Mitigar	Codificación con htmlspecialchars() y política Content-Security-Policy (Control 8.28).	4	Bajo
RSG-17	POL-17	ACT-EXT-07: /exportar.php	Revelación de cadena de conexión a BD (db:3306 / schema interafas) y rutas físicas.	match() sin brazo default y modo DEBUG RESPONSE ENABLED en producción (VULN-05).	5	3	15	Alto	Evitar / Mitigar	Apagar display_errors en producción y agregar default en match (Control 8.9).	2	Bajo
RSG-18	POL-18	ACT-EXT-08: Padrón Proveedores	Alteración fraudulenta del estatus de contratistas estratégicos por usuarios externos.	Rol validado mediante cookie editable portal_role y cabecera X-Required-Role (VULN-06).	5	4	20	Crítico	Mitigar	Gestión de roles exclusivamente en $_SESSION en el servidor (Control 5.15 y 8.2).	3	Bajo
RSG-19	POL-19	ACT-EXT-09: Validación Vínculo	Suplantación de adjudicación contractual por proveedores no relacionados.	Comprobación aislada de contract_id y provider_id sin validar relación (VULN-14).	4	3	12	Alto	Mitigar	Validación mediante INNER JOIN verificando llave foránea en BD (Control 8.26).	2	Bajo
RSG-20	POL-20	ACT-EXT-10: Telemetría y Estado	Exposición pública de topología OT (10.40.20.0/24) y lectura de telemetría sin login.	Fuga en infrastructure-status.php (VULN-15) y falta de sesión en telemetry.php (VULN-17).	5	5	25	Crítico	Evitar / Mitigar	Retirar nodo diagnostics público y exigir sesión activa en telemetría OT (Control 8.12 y 8.5).	4	Bajo

Seccion 07 – Soporte: Minuta de Presentación del SGSI y Soporte Documental de Prevención

7.1 Minuta de Reunión para Dar a Conocer el SGSI

- **Código de Documento:** MIN-SGSI-INTERAFAS-2026-01
- **Fecha y Hora:** 16 de octubre de 2026, 09:00 hrs.
- **Lugar:** Sala de Juntas de Dirección General, INTERAFAS (San Luis Potosí).
- **Asistentes:**
    - Dirección General de INTERAFAS (Preside).
    - Dirección de Tecnologías de la Información y Ciberseguridad (Líder de Proyecto SGSI - Angel Aaron Acuña Quezada).
    - Dirección de Operaciones y Telemetría OT (Responsable de Planta Metropolitana Norte y Red RTU/PLC).
    - Dirección de Administración, Finanzas y Contrataciones (Responsable de Padrón de Proveedores y Pasarela de Pago).
    - Dirección de Comunicación Social y Atención Ciudadana.
- **Orden del Día:**
    1. Presentación de los hallazgos críticos del informe de auditoría ofensiva (INTERAFAS-LAB) y el impacto operacional causado por el incidente.
    2. Formalización del alcance, las 20 políticas funcionales y la matriz de riesgos del SGSI basado en ISO/IEC 27001:2022.
    3. Identificación de áreas de oportunidad y firma de acuerdos vinculantes.
- **Áreas de Oportunidad Identificadas:**
    1. **Desconexión entre equipos de Desarrollo (WebOps) y Seguridad:** Los despliegues desde WEBOPS-03 dejaban archivos .zip, .env y .bak sin limpiar y mantenían activo el modo DEBUG en producción.

2. **Falsa sensación de seguridad en la frontera IT/OT:** Se asumía que el Centro de Operaciones estaba aislado, cuando en realidad compartía alcance desde el servidor web y confiaba en la cabecera X-Forwarded-For.
3. **Falta de cultura de codificación segura y criptografía:** Uso generalizado de validaciones del lado del cliente (cookies de rol, montos de pago en HTML) y contraseñas de soporte OT cifradas con SHA-1 sin sal.

- **Acuerdos y Compromisos (con Fechas y Responsables):**
  - **ACU-01:** La Dirección General aprueba la Política General del SGSI y las 20 Políticas Funcionales con carácter obligatorio a partir de hoy.
  - **ACU-02:** El equipo de Desarrollo Web e Infraestructura deshabilitará de inmediato display_errors, Options +Indexes y corregirá las vulnerabilidades de SQLi, XSS, IDOR y Path Traversal en un plazo máximo de **72 horas**.
  - **ACU-03:** La Dirección de Operaciones OT y TI aislarán a nivel firewall la subred 10.40.20.0/24, rotarán todas las credenciales de soporte a Argon2id y exigirán firma digital RSA en /operations/updates/install.php en un plazo de **48 horas**.
  - **ACU-04:** Se desplegará la campaña de concientización y capacitación técnica obligatoria para todo el personal utilizando el material de soporte documental anexo.

7.2 Soporte Documental en Materia de Prevención

A) Flyer Informativo de Prevención Interna (Diseño Textual y Visual para Distribución Institucional)



B) Estructura de Presentación Ejecutiva y Técnica (Diapositivas de Capacitación)

- **Diapositiva 1 (Portada):** Implementación del SGSI ISO/IEC 27001 en INTERAFAS: De la Deuda Técnica a la Resiliencia Operacional.
- **Diapositiva 2 (El Contexto Real):** Cómo 20 vulnerabilidades encadenadas permitieron pasar de robots.txt al colapso de la unidad RTU-GW-07.
- **Diapositiva 3 (Seguridad en Despliegues WebOps):** Por qué CLEANUP_RELEASE_FILES=yes en papel no basta; prohibición de archivos .bak y modo DEBUG en producción (POL-08, POL-10, POL-17).
- **Diapositiva 4 (Desarrollo Seguro y APIs):** Prevención práctica de IDOR (expediente.php), BOLA (service-history.php), Blind SQLi (validar-referencia.php) y Stored XSS (reportes.php).
- **Diapositiva 5 (Integridad de Reglas de Negocio):** Validación *server-side* de importes en pasarela de pagos (pago.php) y llaves foráneas en contratos (POL-14, POL-18, POL-19).
- **Diapositiva 6 (Blindaje de la Frontera IT/OT):** Aislamiento de la subred 10.40.20.0/24, eliminación de X-Forwarded-For, firmas criptográficas de firmware y protección de setpoints hidráulicos (POL-02, POL-06, POL-09).

C) Temario del Curso Taller de Capacitación Técnica (Duración: 8 Horas)

Módulo 1 (2 hrs): Fundamentos de ISO/IEC 27001:2022 y Responsabilidades Legales en Infraestructura Hídrica. Protección de datos personales (LGPDPPSO) y continuidad del servicio público.

Módulo 2 (2 hrs): Codificación Segura en PHP y Remediación de OWASP Top 10. Laboratorio práctico de migración a PDO Prepared Statements, uso de session_regenerate_id(true), realpath() y htmlspecialchars().

Módulo 3 (2 hrs): Seguridad en APIs y Lógica de Negocio. Eliminación de *Shadow APIs*, control de autorización por objeto (BOLA) y aseguramiento de pasarelas de cobro y licitaciones.

Módulo 4 (2 hrs): Ciberseguridad Industrial (OT) e Integridad de Firmware. Segregación de redes (ISA/IEC 62443), gestión de credenciales con Argon2id, firmado criptográfico de paquetes RTU y límites seguros en HMI/PLC.

Sección 08 – Operación: Matriz de Asignación de Responsabilidades RACI

Para garantizar la correcta operación de los controles del SGSI, se establece la **Matriz RACI**:

- **R (*Responsible* / Responsable):** Quien ejecuta directamente la actividad o el control técnico.
- **A (*Accountable* / Aprobador):** Quien rinde cuentas y tiene la autoridad final de aprobación (solo uno por fila).
- **C (*Consulted* / Consultado):** Quien aporta criterio técnico, legal u operativo antes de la acción.
- **I (*Informed* / Informado):** Quien debe ser notificado de los resultados o cambios.

Proceso / Control Operativo del SGSI	Políticas asociadas	Dirección General (Alta Dirección)	Líder del SGSI / CISO	Equipo WebOps y Desarrollo TI	Administración de BD y Redes	Ingeniería de Operaciones OT	Dirección de Contrataciones y Finanzas	Jurídico y Comunicación Social
1. Aprobación de políticas del SGSI y asignación de recursos	POL-01 a POL-20	A	R	I	I	C	C	I
2. Depuración de despliegues, eliminación de .bak/.zip y endurecimiento de Apache	POL-08, 18, 17	I	A	R	C	I	I	I
3. Remediación de código web: IDOR, BOLA, XSS, Path Traversal y Sesiones	POL-11, 12, 13, 15, 16	I	A	R	C	I	I	C
4. Parametrización PDO contra SQLi y segregación de usuarios en MySQL	POL-01	I	A	C	R	I	I	I
5. Aseguramiento de reglas de negocio en pagos, padrón y contratos	POL-14, 18, 19	I	C	R	I	I	A	C
6. Segregación de red IT/OT (10.40.20.0/24) y bloqueo de X-Forwarded-For	POL-09, 20	I	A	C	R	C	I	I
7. Rotación de hashes Argon2id y firma criptográfica de firmware RTU	POL-06, 07	I	A	C	C	R	I	I
8. Control de alcance en HMI, enclavamientos PLC y límites de presión (3.5-4.8 bar)	POL-02, 03, 04, 05	I	C	I	I	R/A	I	I
9. Atención a incidentes, notificación legal (LGPDPPSO) y comunicación de crisis	—	A	R	C	C	C	I	R

Sección 09 – Evaluación del Desempeño: Lista de Verificación de Auditoría

Con el objetivo de evaluar el cumplimiento y funcionamiento real del SGSI tras su implementación, se aplica la siguiente **Lista de Verificación (Checklist de Auditoría Interna)** sobre las 20 políticas funcionales:

ID Verif	Criterio de Auditoría / Control Verificado	Política Evaluada	Método de Evidencia	Estado	Observaciones del Auditor
CHK-01	¿El 100% de las consultas en validar-referencia.php utilizan PDO Prepared Statements?	POL-01	Revisión de código y prueba con sqlmap.	**CUMPLE**	La inyección booleana ya no altera la respuesta.
CHK-02	¿El panel /operations/firmware.php y la RTU rechazan valores de pressure_setpoint_bar fuera de 3.5–4.8 bar?	POL-02	Prueba de inyección JSON con 10 bar.	**CUMPLE**	El backend devuelve error 422 Out of Safe Range.
CHK-03	¿Las sesiones de mantenimiento en /operations/asset-context.php bloquean la consulta de activos fuera de su ventana?	POL-03	Petición GET hacia asset=ZONE-SL-A.	**CUMPLE**	Acceso restringido únicamente al activo en mantenimiento.
CHK-04	¿Los 18 controladores PLC cuentan con enclavamiento local activo ante sobrepresión?	POL-04	Revisión de lógica de escalera/configuración PLC.	**CUMPLE**	Válvulas de alivio locales operativas.
CHK-05	¿Existen respaldos firmados y fuera de línea en BRS-01 e HIST-01?	POL-05	Inspección de catálogo de recuperación.	**CUMPLE**	Snapshot diario verificado.
CHK-06	¿El instalador /operations/updates/install.php valida la firma digital criptográfica del paquete además del SHA-256?	POL-06	Envío de payload modificado con SHA-256 recalculado.	**NO CUMPLE**	Hallazgo Crítico: ciertos scripts legados de soporte aún permiten omitir la validación de firma RSA cuando se invoca el modo de emergencia sin rotación de llaves.
CHK-07	¿Se eliminaron todos los hashes SHA-1 en firmware_support_users migrando a Argon2id?	POL-07	Auditoría de esquema en base de datos.	**CUMPLE**	Hashes actualizados a formato $argon2id$.
CHK-08	¿El directorio /var/www/html está libre de paquetes .zip, .env y logs de despliegue?	POL-08	Escaneo con gobuster y revisión de /revision/.	**CUMPLE**	Artefactos movidos fuera del document root.
CHK-09	¿El gateway /operations/gateway.php ignora la cabecera X-Forwarded-For y exige red/VPN real?	POL-09	Prueba en Burp Repeater con X-Forwarded-For: 10.40.20.1.	**CUMPLE**	Petición rechazada con 403 Forbidden.
CHK-10	¿Apache tiene Options -Indexes y bloquea extensiones .bak, .old, .swp y ~?	POL-10	Petición curl -I a /transparencia.php.bak.	**CUMPLE**	Archivos eliminados y regla <FilesMatch> activa.
CHK-11	¿/login.php regenera el PHPSESSID al autenticar e invalida sesiones reutilizadas?	POL-11	Inspección de Set-Cookie en Burp Suite.	**CUMPLE**	Nuevo ID emitido tras POST /login.php.
CHK-12	¿/expediente.php impide consultar registros de otros ciudadanos al cambiar ?id=2?	POL-12	Prueba de cambio de parámetro con ciudadano01.	**CUMPLE**	El servidor valida usuario_id en sesión.
CHK-13	¿/descargar-documento.php bloquea secuencias ../ hacia /etc/passwd y /etc/motd?	POL-13	Prueba en Burp Repeater con ../../../../../etc/motd.	**CUMPLE**	basename() y realpath() bloquean el salto.
CHK-14	¿/pago.php ignora modificaciones al campo monto y cobra el saldo real de la factura?	POL-14	Envío de POST con monto=1.00 en factura de $399.24.	**CUMPLE**	Importe tomado directamente de la base de datos.
CHK-15	¿/api/service-history.php está documentado y bloquea la consulta de la cuenta 40010002 desde otra sesión?	POL-15	Prueba de petición cruzada con curl.	**CUMPLE**	Devuelve 403 Forbidden ante cuentas ajenas.
CHK-16	¿/seguimiento-reporte.php codifica la salida con htmlspecialchars() bloqueando etiquetas <script>?	POL-16	Inyección de prueba en /reportes.php.	**CUMPLE**	El script se muestra como texto inofensivo y aplica CSP.
CHK-17	¿/exportar.php cuenta con cláusula default en match() y tiene desactivado el modo DEBUG RESPONSE?	POL-17	Petición a /exportar.php?tipo=xyz123.	**CUMPLE**	Devuelve mensaje genérico sin rutas ni datos de BD.
CHK-18	¿Se eliminó la cookie portal_role y la cabecera X-Required-Role en /gestion-proveedores.php?	POL-18	Inspección de cabeceras y cookies en navegador.	**CUMPLE**	Rol validado exclusivamente en $_SESSION.
CHK-19	¿/validar-vinculo-contractual.php verifica mediante INNER JOIN que el contrato pertenezca al proveedor indicado?	POL-19	Cruce de contract_id=51 con provider_id=107.	**CUMPLE**	Rechaza combinaciones inconsistentes.
CHK-20	¿Se eliminó el bloque diagnostics de /api/infrastructure-status.php y se exige login en /operations/telemetry.php?	POL-20	Inspección de respuesta JSON y prueba sin sesión.	**CUMPLE**	Sin fuga de IPs OT; telemetría exige sesión válida.

Sección 10 – Mejora Continua: Rediseño de Soporte y Mejora de Política Funcional

Derivado de la no conformidad detectada en el criterio **CHK-06** de la lista de verificación (donde la **Política Funcional POL-06** sobre validación de paquetes de firmware OT no logró su objetivo al 100% debido a que el personal técnico mantenía una excepción manual sin firma para "mantenimientos de emergencia"), se ejecuta el ciclo de **Mejora Continua (Cláusula 10 de ISO/IEC 27001)** mediante dos acciones correctivas estructurales:

10.1 Mejora de la Política Funcional POL-06 (Versión 2.0)

Se actualiza y endurece la política POL-06 eliminando cualquier excepción que permita instalar paquetes basados únicamente en sumas SHA-256:

Elemento	Versión Inicial (POL-06 v1.0 – No logró el objetivo)	Versión Mejorada (POL-06 v2.0 – Corregida tras Auditoría)
Declaración de la Política	Todo paquete de actualización de firmware para dispositivos OT deberá estar firmado criptográficamente antes de su instalación.	Cero excepciones en integridad de firmware OT: Ningún dispositivo RTU o PLC (incluyendo RTU-GW-07) aceptará paquetes de firmware o cambios de estado de diagnóstico sin verificación criptográfica asimétrica (ECDSA P-384) validada por hardware (HSM/TPM) y token
Estándar	ISO 27002 8.24 (Uso de criptografía) y OWASP A08.	ISO 27002 8.24, 8.32 (Gestión de cambios) e ISA/IEC 62443-4-2 (Autenticidad de actualizaciones en componentes embebidos).
Directriz	No confiar únicamente en sumas SHA-256 enviadas por el cliente.	Queda prohibida y eliminada del código cualquier bandera de bypass o modo de emergencia que degrade la validación a checksum-only. El atributo diagnostic: UNLOCKED no podrá enviarse dentro del payload JSON de red, requiriendo activación física local en
Procedimiento	1. Firmar paquete. 2. Verificar en install.php. 3. Abortar si falla.	1. Compilar firmware en entorno aislado y firmar con llave privada custodiada en HSM. 2. En install.php, verificar cabecera X-Firmware-Signature con llave pública fija en solo lectura. 3. Validar coincidencia con ID de ventana activa (MW-XXXXXX) en base de datos. 4. Bloquear cambios remotos al campo diagnostic.
Línea Base	Firma RSA-2048 obligatoria; estado por defecto diagnostic: LOCKED.	Firma ECDSA P-384 obligatoria en el 100% de endpoints (/operations/updates/install.php y /operations/firmware.php); propiedad diagnostic fijada permanentemente en LOCKED para interfaces remotas.

10.2 Rediseño del Soporte Documental de Prevención (Enfocado al Personal de Ingeniería y Soporte OT

Dado que el flyer y la capacitación general no evitaron que el personal de soporte utilizara atajos durante las ventanas de mantenimiento, se rediseña el soporte preventivo creando una **Guía Rápida de Bolsillo (Checklist Operativo Pre-Mantenimiento OT)** pegada físicamente en las estaciones de ingeniería (EWS-01 y consola HMI-OPS-01) y un **Módulo Práctico de Laboratorio de Crisis**

SOPORTE PREVENTIVO REDISEÑADO INGENIERÍA Y MANTENIMIENTO OT

🛠️ PROTOCOLO OBLIGATORIO
ANTES DE ACTUALIZAR FIRMWARE
EN RTU-GW-07 / PLCs

¡ATENCIÓN INGENIERO!

UN HASH SHA-256 NO ES UNA FIRMA DIGITAL. EN EL INCIDENTE PASADO, EL ATACANTE MODIFICÓ EL JSON A "DIAGNOSTIC: UNLOCKED", CALCULÓ SU PROPIO SHA-256 Y TOMÓ EL CONTROL DE LA PLANTA PORQUE EL SISTEMA SOLO VERIFICABA EL CHECKSUM.

ANTES DE EJECUTAR CUALQUIER ACTUALIZACIÓN

- PASO 1: VERIFICA QUE EXISTA UNA VENTANA ACTIVA AUTORIZADA (EJ. MW-260925-01).
- PASO 2: COMPRUEBA LA FIRMA CRIPTOGRÁFICA (.SIG) DEL PAQUETE USANDO LA LLAVE PÚBLICA OFICIAL DE INTERAFAS (OPENSSL DGST -SHA384 -VERIFY).
- PASO 3: CONFIRMA QUE EL PAYLOAD MANTENGA "DIAGNOSTIC": "LOCKED" Y QUE EL SETPOINT DE PRESIÓN SEA EXACTAMENTE 4.2 BAR (RANGO: 3.5 A 4.8 BAR).
- PASO 4: SOLICITA LA SEGUNDA FIRMA DIGITAL DEL SUPERVISOR DE TURNO EN EL HMI.